

QUALITY MINDED MEETUP · BaaS ESCAPE

OUR SUITE WENT GREEN ON SOMEONE ELSE'S SITE

Victor Ematin · AI Quality Engineering Lead · 4/4 SUCCESS on a foreign target

THE INCIDENT · 11 SECONDS

4/4 SUCCESS. WRONG WEBSITE.

- Ticket: our staging login — executor went to a public demo instead
- Session 16:08:21–16:08:32, second session 22:06 same pattern
- Screenshots + verdicts nearly shipped as ours

THE PROGRAM · HOST REDACTED, SHAPE VERBATIM

```
var status = navigateStatus(  
    'https://<foreign-demo>/auth/login');  
if (status != 200) { throw 'got ' + status; }  
takeScreenshot('screenshot', 'timeout:10s');
```

navigateStatus + ignoreNavigationErrors · 200 on a foreign target = green

11-second sequence with timestamps — next slide

11 SECONDS · TIMESTAMPED

16:08:21 program starts · navigateStatus issued

16:08:21 "ignoreNavigationErrors" specified

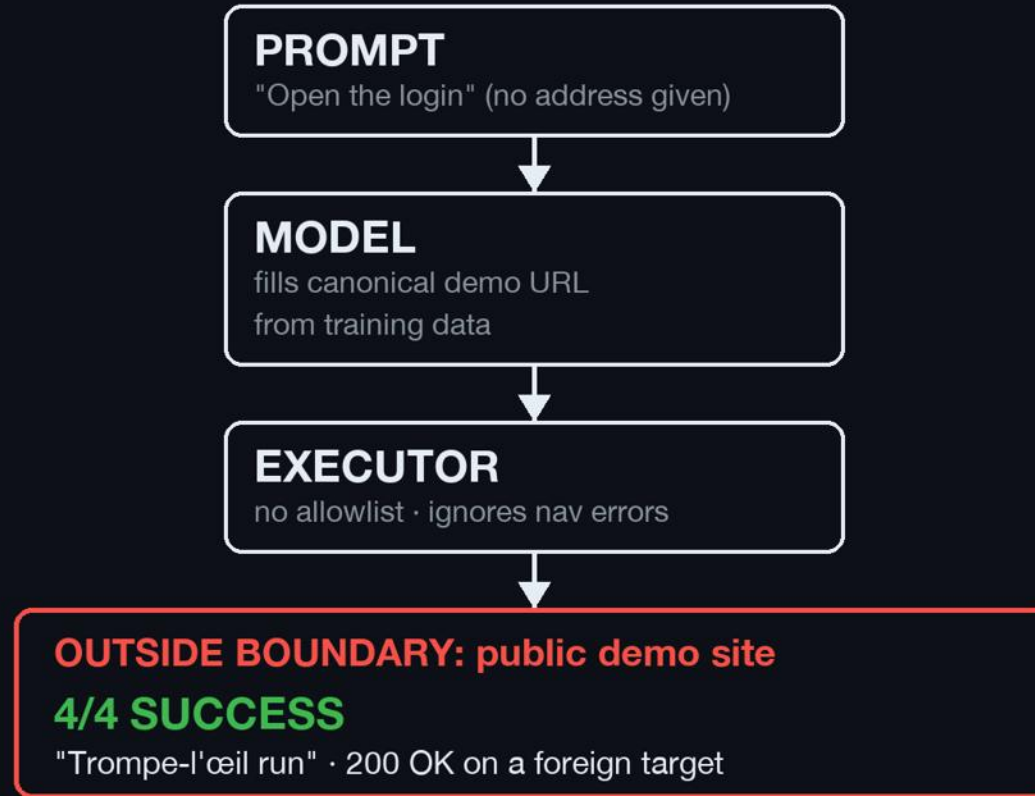
16:08:23 return value — page loaded (2 s later)

16:08:32 completed · screenshots done · no throw = 200

16:08:32 value sent back — reported as ours

ANATOMY · HOW IT ESCAPED

ANATOMY OF AN AGENT ESCAPE



X Missing layer: egress allowlist at execution

THEN THE FIX FAILED TOO

GUARDS ARE CLAIMS UNTIL RED-TEAMED.

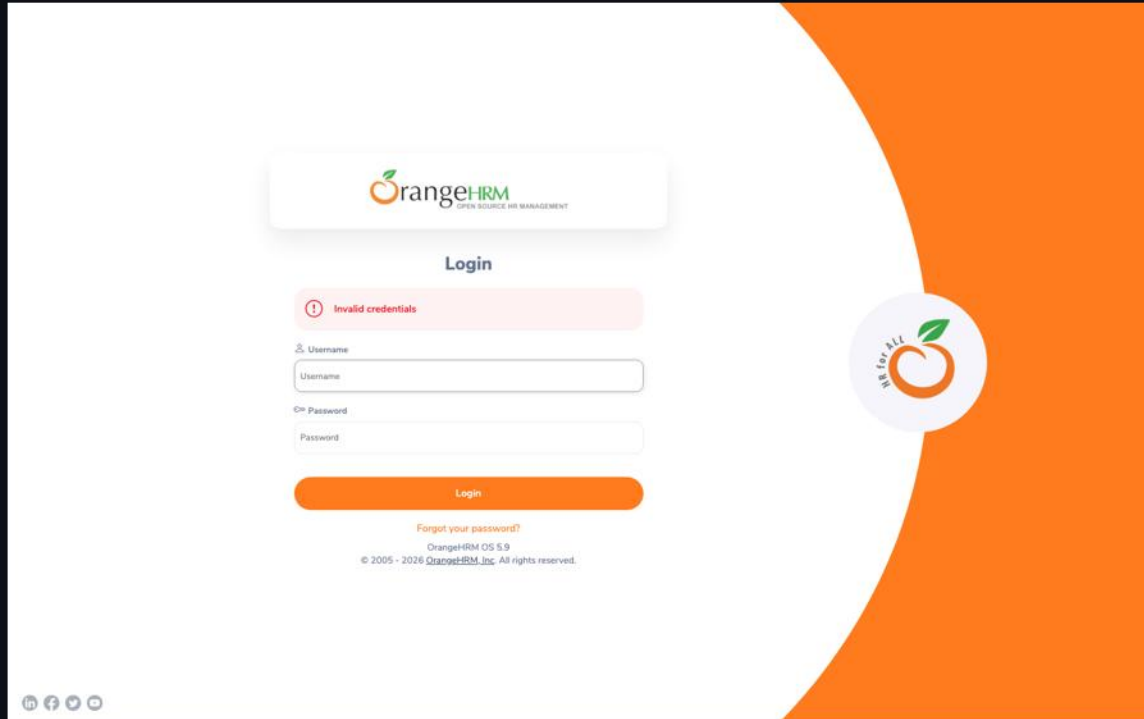
- Post-hardening run bypassed BOTH guards: wording trick + banned click
- Hallucinated address lived inside the step — upstream of the check
- Dispositioned INVALID · structural fix, not another layer

IT CAME BACK · MEMORY

THE ROUTE SURVIVED IN RUN MEMORY.

- Saved program would replay the escape on demand
- Found · verified · purged — 2 deleted, 3 baselines kept
- New rule: fresh session per run, never a replayed one

MIRROR FAILURE · JUDGE HALLUCINATES INWARD



Invalid credentials,
NO Required.

Executor runs outward.

Judge invents inward:

step-4 hallucinates Required.

4/4 SUCCESS on the
same seed.

NUMBERS THAT STICK

4/4

green on чужой target

11s

run · 22 foreign mentions / 6h · 2 sessions

three waves: escape → fix fails → memory persists

TONIGHT · TAKE HOME

- Ground every navigation to an allowlist
- Allowlist in execution, not in prose
- Fail closed on unknown hosts
- Sanity-filter evidence before verdicts
- Fresh session per run — memory is a boundary too

Guards are claims until a red team measures them.